

INFORME DE AUDITORÍA DE SEGURIDAD WEB



- Autor: Marcos Cabello Vargas
- Fecha : 14/08/2025
- Entorno: <https://tssciberseguridad.com>

ÍNDICE

- 1. INTRODUCCIÓN
- 2.OBJETIVOY ALCANCE
- 3.SUMARIO EJECUTIVO
- 4.VULNERABILIDADES
- 5.RECOMENDACIONES
- 6.EVIDENCIAS
- 7.CONCLUSIÓN

INTRODUCCIÓN

- En el marco de la presente auditoría de seguridad web, se ha analizado el dominio <https://tssciberseguridad.com> con el objetivo de identificar posibles vulnerabilidades asociadas a su exposición pública.
- El sitio analizado utiliza como tecnología principal el gestor de contenidos WordPress, lo que ha guiado el enfoque del análisis hacia vectores de ataque comunes en este tipo de entornos.
- Durante la auditoría, se han empleado técnicas de reconocimiento, recolección de información y escaneo pasivo y activo, respetando en todo momento los límites establecidos por la ética profesional y las condiciones de la práctica.
- Este informe presenta de forma estructurada los hallazgos encontrados, clasificándolos según su nivel de criticidad y proponiendo recomendaciones de mejora.

OBJETIVO Y ALCANCE

- El objetivo de esta auditoría es analizar el nivel de seguridad del sitio web público identificado con el dominio <https://tssciberseguridad.com>, con el fin de detectar vulnerabilidades técnicas, configuraciones inseguras o prácticas que puedan exponer a riesgos la confidencialidad, integridad o disponibilidad del sistema.

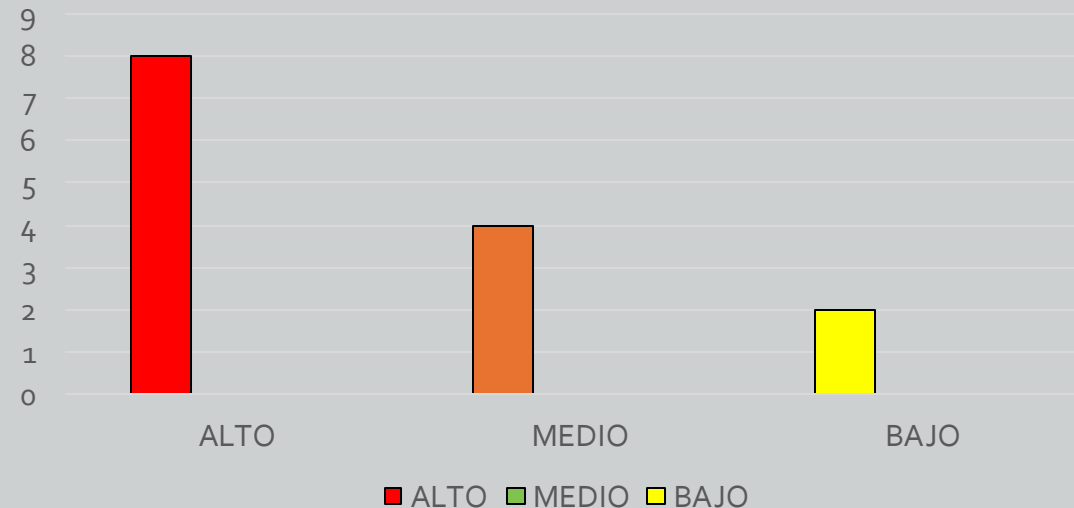
SUMARIO EJECUTIVO

- Durante la auditoría web realizada sobre el sitio <https://tssciberseguridad.com>, se identificaron varias configuraciones y vectores potencialmente vulnerables. Las principales observaciones incluyen:
 - Cabeceras de seguridad incompletas o mal configuradas.
 - XML-RPC habilitado, lo que puede facilitar ataques como DoS o fuerza bruta si no está protegido.
 - Enumeración de usuarios.
 - Registro de usuarios habilitado públicamente.
 - Listado completo de rutas y páginas sensibles.
 - Presencia de archivos restringidos accesibles mediante fuzzing.
 - Plugins y temas detectados.
- Estas configuraciones, en conjunto, pueden facilitar un ataque escalado si no se gestionan adecuadamente.

CLASIFICACIÓN DE VULNERABILIDADES

- Las vulnerabilidades se clasifican conforme a los siguientes criterios:
 - **Alto:** Permite acceso a información sensible, credenciales o enumeración de usuarios clave.
 - **Medio:** Expone información técnica no sensible, configuraciones inseguras o servicios innecesarios.
 - **Bajo:** Corresponde a configuraciones por defecto, servicios con información mínima o métodos que, por sí solos, no representan riesgo directo, pero podrían ser aprovechados en combinación con otras debilidades.

GRÁFICO DE VULNERABILIDADES



VULNERABILIDAD	RIESGO	DESCRIPCIÓN	CVE	RECOMENDACIONES
XML-RPC habilitado	ALTO	Permite ejecutar múltiples funciones de WordPress remotamente, lo cual puede ser abusado para ataques de fuerza bruta o DDoS.	CWE-917	Deshabilitar xmlrpc.php si no es utilizado o limitar su acceso mediante reglas del servidor.
Acceso al archivo readme.html de WordPress	MEDIO	Este archivo revela información sobre la versión de WordPress utilizada, lo cual puede facilitar ataques dirigidos.	CWE-200	Eliminar o restringir el acceso al archivo readme.html tras la instalación.
Métodos HTTP habilitados indebidamente	MEDIO	Ausencia de cabeceras como Strict-Transport-Security, X-Frame-Options, Content-Security-Policy, etc.	CWE-693	Configurar correctamente las cabeceras de seguridad HTTP en el servidor web.
Enumeración de usuarios vía RSS	MEDIO	Exposición de nombres de usuario reales en el feed RSS, lo que facilita ataques dirigidos de fuerza bruta.	CWE-200	Restringir la exposición de autores en feeds o plugins de seguridad que oculten esta información.
Archivos sensibles accesibles	BAJO	Se identificaron los archivos license.txt y robots.txt accesibles públicamente en la raíz del sitio web. El archivo license.txt contiene la licencia del software utilizado, lo que confirma la tecnología y versión de WordPress. El archivo robots.txt expone la política de indexación del sitio, pudiendo facilitar a un atacante la identificación de rutas internas o restringidas	---	Limitar el acceso a ficheros innecesarios en producción. Revisar y depurar el contenido de robots.txt para no incluir rutas sensibles. Aplicar reglas en el servidor web para restringir el acceso a archivos que no sean imprescindibles para el funcionamiento del sitio.
Subdominios detectados no auditados	BAJO	Presencia de subdominios potencialmente expuestos como moodle., formacion., emails. que podrían tener servicios vulnerables.	CWE-918	Realizar auditorías específicas sobre cada subdominio descubierto.

RECOMENDACIONES

- Deshabilitar o proteger el endpoint XML-RPC.
- Aplicar cabeceras de seguridad robustas: CSP, X-Content-Type, etc.
- Desactivar el registro público si no es estrictamente necesario.
- Implementar un WAF que bloquee enumeración automática y fuerza bruta.
- Revisar los plugins y temas activos en WordPress, eliminando los innecesarios o desactualizados.
- Evitar que el sitemap index muestre rutas internas no deseadas.
- Reforzar el fichero .htaccess para bloquear accesos a archivos de sistema (como error_log, .git, etc).

EVIDENCIAS

- A continuación, se presentan las capturas de pantalla obtenidas durante el análisis de seguridad del host auditado. Estas evidencias respaldan las vulnerabilidades descritas en el informe principal, permitiendo validar los puertos abiertos, los servicios expuestos y configuraciones detectadas que representan un riesgo para el sistema.

Evidencia 1 – XML-RPC Habilitado

- **Nivel de riesgo: ALTO**
- Es un protocolo antiguo que permite ejecutar acciones remotas en un servidor (como WordPress, Drupal o APIs personalizadas). Cuando está habilitado innecesariamente, se convierte en un riesgo de seguridad porque:
 - **Riesgos principales:**
 - Ataques de Fuerza Bruta:
 - XML-RPC permite múltiples intentos de autenticación en una sola solicitud (system.multicall), facilitando ataques de fuerza bruta contra contraseñas.
 - DDoS Amplification:
 - Un atacante puede usar XML-RPC para generar solicitudes pesadas y saturar el servidor (ataques Pingback/Trackback).
 - Ejecución Remota de Código (RCE):
 - Vulnerabilidades en la implementación de XML-RPC pueden permitir inyección de comandos o manipulación de datos.
 - Exposición de Información
- **Recomendaciones:** Deshabilitar xmlrpc.php si no es utilizado o limitar su acceso mediante reglas del servidor.

```
/xmlrpc.php (Status: 405) [Size: 42]  
/xmlrpc.php.txt (Status: 403) [Size: 199]  
/xmlrpc.php (Status: 405) [Size: 42]
```

Evidencia 2 – Acceso al archivo readme.html

- **Nivel de riesgo: MEDIO**
- El archivo readme o readme.html normalmente contiene información de documentación, instrucciones o detalles técnicos sobre la aplicación o el sitio web. En muchos casos, puede incluir:
 - Información sobre plugins o módulos instalados.
 - Configuraciones internas.
 - Advertencias o detalles que podrían ayudar a un atacante a conocer el entorno.
 - Esta información facilita el trabajo de un atacante, porque puede revelar versiones vulnerables o configuraciones que pueden ser explotadas.
- **Recomendaciones:** Eliminar o restringir el acceso al archivo readme.html tras la instalación.

```
> GET /readme.html HTTP/1.1  
> Host: tssciberseguridad.com
```

Evidencia 3 – Métodos HTTP habilitados indebidamente

- **Nivel de riesgo: MEDIO**
- Tener cabeceras HTTP mal configuradas o expuestas puede revelar información sensible (versiones de software, rutas internas, métodos HTTP permitidos) y facilitar ataques como:
 - Exposición a exploits conocidos (ej: ataques a versiones antiguas de Apache/Nginx).
 - Pérdida de confidencialidad (datos de servidor, frameworks).
 - Aumento de superficie de ataque.
- **Recomendaciones:** Configurar correctamente las cabeceras de seguridad HTTP en el servidor web.

```
[INF] Using Interactsh Server: oast.live
[http-missing-security-headers:x-permitted-cross-domain-policies] [http] [info] https://tssciberseguridad.com
[http-missing-security-headers:clear-site-data] [http] [info] https://tssciberseguridad.com
[http-missing-security-headers:cross-origin-embedder-policy] [http] [info] https://tssciberseguridad.com
[http-missing-security-headers:cross-origin-opener-policy] [http] [info] https://tssciberseguridad.com
[http-missing-security-headers:cross-origin-resource-policy] [http] [info] https://tssciberseguridad.com
```

Evidencia 4–Enumeración de usuarios vía RSS

- **Nivel de riesgo: MEDIO**
- El feed RSS del sitio web expone los nombres de usuario reales de los autores, lo que facilita ataques dirigidos de fuerza bruta. Esta información permite a un atacante conocer cuentas válidas para intentar comprometerlas mediante técnicas de adivinación de contraseñas.
- **Recomendaciones:** Restringir la exposición de autores en feeds o plugins de seguridad que oculten esta información.

```
[+] Enumerating Users (via Passive and Aggressive Methods)
Brute Forcing Author IDs - Time: 00:00:05 ←

[i] User(s) Identified:

[+] Rafa
| Found By: Rss Generator (Passive Detection)
| Confirmed By: Rss Generator (Aggressive Detection)

[+] Paco
| Found By: Rss Generator (Passive Detection)
| Confirmed By: Rss Generator (Aggressive Detection)
```

Evidencia 5–Archivos sensibles accesibles

- **Nivel de riesgo: BAJO**
- Durante el análisis se identificó que los archivos `license.txt` y `robots.txt` están accesibles públicamente desde la raíz del dominio, sin requerir autenticación.
- El archivo `license.txt` contiene información sobre la licencia de WordPress utilizada, mientras que `robots.txt` incluye directivas que pueden revelar partes de la estructura del sitio.
- **Recomendaciones:**
 - Limitar el acceso a ficheros innecesarios en producción.
 - Revisar y depurar el contenido de `robots.txt` para no incluir rutas sensibles.
 - Aplicar reglas en el servidor web para restringir el acceso a archivos que no sean imprescindibles

```
license.txt      [Status: 200, Size: 19903, Words: 3331, Lines: 385, Duration: 59ms]  
robots.txt      [Status: 200, Size: 82, Words: 3, Lines: 5, Duration: 46ms]
```


Evidencia 6–Subdominios detectados no auditados

- **Nivel de riesgo: BAJO**
- Se han identificado varios subdominios (moodle, formacion, emails) que no fueron incluidos en el alcance de esta auditoría. Estos subdominios representan una posible ampliación de la superficie de ataque, ya que podrían contener servicios vulnerables o configuraciones inseguras que no han sido evaluadas.
- **Recomendaciones:** Realizar auditorías específicas sobre cada subdominio descubierto.

```
https://tssciberseguridad.com/  
https://tssciberseguridad.com/affiliate-reset-password/  
https://tssciberseguridad.com/registro-de-afiliados/  
https://tssciberseguridad.com/cuenta-de-afiliado/  
https://tssciberseguridad.com/speedmaster-de-seguridad-ofensiva/  
https://tssciberseguridad.com/quienes-somos/  
https://tssciberseguridad.com/contacto/  
https://tssciberseguridad.com/clientes-colaboradores/  
https://tssciberseguridad.com/formacion-en-ciberseguridad/  
https://tssciberseguridad.com/necesito-mas-informacion-sobre-la-academia-online/  
https://tssciberseguridad.com/servicios-de-ciberseguridad/  
https://tssciberseguridad.com/esquema-nacional-de-seguridad/  
https://tssciberseguridad.com/master-privado-de-experto-en-ciberseguridad/  
https://tssciberseguridad.com/curso-online-y-directo/  
https://tssciberseguridad.com/blog/  
https://tssciberseguridad.com/master-privado-de-perito-informatico-forense/  
https://tssciberseguridad.com/master-privado-de-hacking-etico/  
https://tssciberseguridad.com/promociones/  
https://tssciberseguridad.com/eset-antivirus/
```

```
/wp-admin (Status: 301) [Size: 246] [→ http://tssciberseguridad.com/wp-admin/]  
/wp-app.php (Status: 403) [Size: 0]  
/wp-atom.php (Status: 301) [Size: 0] [→ https://tssciberseguridad.com/feed/atom/]  
/wp-commentsrss2.php (Status: 301) [Size: 0] [→ https://tssciberseguridad.com/comments/feed/]  
/wp-config.php (Status: 403) [Size: 199]  
/wp-content (Status: 301) [Size: 248] [→ http://tssciberseguridad.com/wp-content/]  
/wp-cron.php (Status: 200) [Size: 0]  
/wp-feed.php (Status: 301) [Size: 0] [→ https://tssciberseguridad.com/feed/]  
/wp-includes (Status: 301) [Size: 249] [→ http://tssciberseguridad.com/wp-includes/]  
/wp-links-opml.php (Status: 200) [Size: 235]  
/wp-load.php (Status: 200) [Size: 0]  
/wp-login.php (Status: 200) [Size: 11963]  
/wp-mail.php (Status: 403) [Size: 3420]  
/wp-rdf.php (Status: 301) [Size: 0] [→ https://tssciberseguridad.com/feed/rdf/]  
/wp-register.php (Status: 301) [Size: 0] [→ https://tssciberseguridad.com/wp-login.php?action=register]  
/wp-rss.php (Status: 301) [Size: 0] [→ https://tssciberseguridad.com/feed/]  
/wp-rss2.php (Status: 301) [Size: 0] [→ https://tssciberseguridad.com/feed/]  
/wp-settings.php (Status: 500) [Size: 0]  
/wp-signup.php (Status: 302) [Size: 0] [→ https://tssciberseguridad.com/wp-login.php?action=register]  
xmlrpc.php (Status: 405) [Size: 42]  
xmlrpc.php.txt (Status: 403) [Size: 199]  
xmlrpc.php (Status: 405) [Size: 42]  
/~adm (Status: 301) [Size: 0] [→ https://tssciberseguridad.com/leccion/administracion-publica/]  
/~admin (Status: 301) [Size: 0] [→ https://tssciberseguridad.com/leccion/administracion-publica/]
```

CONCLUSIÓN

- La superficie web analizada no presenta vulnerabilidades críticas, sin embargo, se detectaron ciertas malas prácticas de configuración que podrían representar un riesgo en escenarios más complejos o ante atacantes persistentes.
- Se recomienda realizar las modificaciones propuestas en este informe para reducir la superficie de ataque y elevar el nivel de protección frente a amenazas comunes.
- Este informe cubre exclusivamente la auditoría del servicio web (HTTP) del host 192.168.88.146.